

CSRF with Broken Referer Validation

Platform: PortSwigger Web Security Academy

Category: Cross-Site Request Forgery (CSRF)

Tools: Burp Suite, Web Browser

Objective

Exploit a CSRF vulnerability caused by improper validation of the HTTP **Referer** header, allowing a cross-site request to bypass the application's security checks.

Vulnerability

The application uses the **Referer** header to verify the origin of incoming requests. However, its validation logic is incorrectly implemented, allowing an attacker to manipulate the header value in a way that bypasses the intended security check.

Unlike robust origin validation, flawed string matching or incomplete domain verification may allow requests from untrusted sources to be accepted.

Methodology

1. Intercepted a sensitive, state-changing request using Burp Suite.
2. Examined the application's **Referer** validation behavior.
3. Tested how the application handled modified Referer values.
4. Identified a validation weakness that allowed the security check to be bypassed.
5. Crafted a proof-of-concept CSRF request that exploited the validation flaw.
6. Confirmed that the application accepted the unauthorized request and completed the lab.

Impact

An attacker may trick an authenticated victim into submitting an unintended request. Depending on the affected functionality, this could result in unauthorized account changes or other state-changing actions.

Remediation

- Validate the **Origin** and **Referer** headers using strict URL and hostname parsing.
- Avoid insecure substring-based domain checks.
- Implement unpredictable, session-bound CSRF tokens.
- Use appropriate **SameSite** cookie settings as an additional defense.
- Require re-authentication for particularly sensitive operations where appropriate.

References

- PortSwigger Web Security Academy – CSRF
- OWASP Cross-Site Request Forgery Prevention Cheat Sheet
-